RGPD : Audit de la société X-Corp

(par Ahmed et Abdillah)

Job 1 : Rapport synthétique

Les concepts clés du RGPD

Introduction

Le Règlement général sur la protection des données (RGPD) est le texte européen de référence concernant la protection des données à caractère personnel. Applicable depuis le 25 mai 2018, il vise à renforcer les droits des citoyens et à responsabiliser les organismes qui collectent et utilisent leurs données.

Le RGPD concerne les entreprises, administrations et associations qui traitent des données personnelles dans le cadre de leurs activités. Son objectif est de permettre l'utilisation des données tout en garantissant le respect de la vie privée. Il repose notamment sur trois idées essentielles : limiter la collecte aux données nécessaires, garantir les droits des personnes et responsabiliser les organismes qui utilisent ces informations.

1. Les données personnelles et leur traitement

Une donnée personnelle correspond à toute information permettant d'identifier directement ou indirectement une personne physique. Il peut s'agir du nom, du prénom, de l'adresse, du numéro de téléphone ou de l'adresse électronique, mais également d'une adresse IP, d'un identifiant client ou de données de géolocalisation.

Certaines données sont considérées comme particulièrement sensibles. C'est notamment le cas des informations relatives à la santé, aux opinions politiques, aux convictions religieuses, à l'origine raciale ou ethnique, ainsi que de certaines données biométriques. Leur traitement est en principe interdit, sauf dans les situations expressément prévues par le RGPD.

La notion de traitement est également très large. Elle désigne toute opération réalisée sur des données personnelles : collecte, enregistrement, classement, consultation, modification, transmission, conservation ou suppression.

Exemple concret : lorsqu'une entreprise reçoit le CV d'un candidat, l'enregistre dans son logiciel de recrutement puis le consulte afin d'étudier sa candidature, elle réalise un traitement de données personnelles.

2. Les principes fondamentaux du RGPD

Le RGPD impose plusieurs principes destinés à encadrer l'utilisation des données.

Licéité, loyauté et transparence

Tout traitement doit avoir une justification juridique, appelée base légale. Le RGPD en prévoit six, parmi lesquelles figurent le consentement, l'exécution d'un contrat, le respect d'une obligation légale et l'intérêt légitime.

Le consentement n'est donc pas obligatoire pour tous les traitements. Lorsqu'il est utilisé, il doit notamment être libre, spécifique, éclairé et univoque. L'organisme doit également informer clairement la personne de l'utilisation qui sera faite de ses données.

Exemple : une boutique en ligne peut utiliser l'adresse d'un client pour lui livrer sa commande sur la base de l'exécution du contrat. Elle n'a donc pas besoin de demander son consentement pour effectuer cette opération.

Finalité et minimisation des données

Les données doivent être collectées pour une finalité déterminée et ne doivent pas être utilisées de manière incompatible avec l'objectif annoncé. Le principe de minimisation impose également de ne collecter que les informations réellement nécessaires.

Par exemple, pour inscrire une personne à une newsletter, son adresse électronique peut suffire. Demander systématiquement sa date de naissance, son adresse postale ou sa situation familiale serait difficile à justifier si ces informations ne sont pas nécessaires au service proposé.

Durée de conservation

Les données personnelles ne peuvent pas être conservées indéfiniment. Leur durée de conservation doit être proportionnée à la finalité du traitement. Lorsqu'elles ne sont plus nécessaires, elles doivent, selon les situations, être supprimées, anonymisées ou archivées conformément aux règles applicables.

Exemple : une entreprise ne devrait pas conserver pendant plusieurs dizaines d'années tous les CV reçus simplement au motif qu'elle pourrait éventuellement contacter ces candidats dans le futur.

Sécurité des données

Les organismes doivent mettre en place des mesures adaptées pour empêcher la perte, la modification ou l'accès non autorisé aux données. Ces mesures peuvent comprendre la gestion des droits d'accès, l'utilisation de mots de passe robustes, les sauvegardes, le chiffrement ou la sensibilisation des salariés.

Le RGPD prévoit également le principe de « privacy by design » : la protection des données doit être prise en compte dès la conception d'un produit ou d'un service.

Exemple : lors de la création d'une application mobile, l'entreprise doit déterminer dès le départ quelles données sont réellement nécessaires et éviter de demander des autorisations sans rapport avec son fonctionnement.

3. Les droits des personnes et les obligations des organismes

Les principaux droits

Le RGPD donne aux personnes plusieurs moyens de contrôler l'utilisation de leurs informations. Elles disposent notamment :

- du droit d'accès, pour connaître les données détenues par un organisme ;
- du droit de rectification, pour corriger des informations inexactes ;
- du droit à l'effacement, lorsque les conditions prévues par le RGPD sont réunies ;
- du droit d'opposition à certains traitements ;
- du droit à la limitation du traitement ;
- du droit à la portabilité, applicable dans certaines situations.

Exemple : un utilisateur peut demander à une plateforme une copie des données associées à son compte et faire rectifier une adresse incorrecte. Selon la situation, il peut également demander la suppression de certaines informations.

La responsabilité des organismes

Le RGPD repose sur le principe d'accountability, ou responsabilité. Une organisation ne doit pas seulement respecter les règles : elle doit être capable de démontrer sa conformité.

Le registre des activités de traitement constitue l'un des principaux outils permettant de documenter les traitements réalisés. Il permet notamment d'identifier les catégories de données utilisées, leurs finalités, leurs destinataires et leurs durées de conservation.

Lorsqu'un traitement est susceptible d'entraîner un risque élevé pour les droits et libertés des personnes, l'organisme doit également déterminer si une analyse d'impact relative à la protection des données (AIPD) est nécessaire. Certains organismes doivent par ailleurs désigner un délégué à la protection des données (DPO), chargé de conseiller et d'accompagner la structure dans sa conformité.

Les violations de données et les sanctions

Une violation peut correspondre à une perte, une divulgation ou un accès non autorisé à des données personnelles. Lorsqu'elle présente un risque pour les droits et libertés des personnes, l'organisation doit en principe notifier la violation à l'autorité de contrôle compétente dans les meilleurs délais et, si possible, dans les 72 heures suivant sa découverte.

Exemple : si une entreprise subit une cyberattaque donnant accès à sa base clients, elle doit analyser rapidement les données compromises, limiter les conséquences de l'incident et déterminer si elle doit prévenir la CNIL et les personnes concernées.

Le non-respect du RGPD peut entraîner différentes sanctions. Pour les infractions les plus graves, les amendes administratives peuvent atteindre 20 millions d'euros ou 4 % du chiffre d'affaires annuel mondial, le montant le plus élevé étant retenu. Au-delà du risque financier,

une violation peut également entraîner une perte de confiance des clients et nuire à la réputation de l'organisation.

Conclusion

Le RGPD constitue un cadre essentiel pour protéger les personnes face à l'utilisation croissante de leurs données. Il impose aux organisations de déterminer précisément quelles données elles collectent, pourquoi elles les utilisent, pendant combien de temps elles les conservent et comment elles les protègent.

La conformité repose ainsi sur trois principes majeurs : collecter uniquement les données nécessaires, garantir aux personnes le contrôle de leurs informations et responsabiliser les organismes qui les utilisent. Le RGPD ne constitue donc pas uniquement une obligation juridique : il contribue également à instaurer une relation de confiance entre les organisations et les utilisateurs.

Sources

- Dastra, *Qu'est-ce que le RGPD ?*
- Règlement (UE) 2016/679 du Parlement européen et du Conseil.
- CNIL, ressources relatives au Règlement général sur la protection des données.

Job 2 : Registre des traitements X-Corp

X-Corp			
Rubrique	RetailCo	HealthMed	EduLearn
Nom du traitement	Gestion des clients	Suivi des patiens	Analyse de l'usage
Finalité	Personnalisation des offres et des promotions, amélioration de l'expérience client.	Noms, adresses, emails, numéros de téléphone, historique médical, prescriptions.	Amélioration des parcours d'apprentissage, recommandations de cours, suivi des progrès.
Personne concernées	Clients	Patiens	Utilisateurs
Données collectées	Noms, adresses, emails, numéros de téléphone, historique d'achats, préférences de produits.	Noms, adresses, emails, numéros de téléphone, historique médical, prescriptions.	Identifiants utilisateurs, adresses email, parcours d'apprentissage, résultats d'examen.

X-Corp			
Base légale	Consentement des clients.	Consentement explicite des patients.	consentement des utilisateurs.
Durée de conservation	5 ans après le dernier contact.	10 ans après la fin du traitement médical.	2 ans après la fin de l'utilisation de la plateforme.
Mesures de sécurité	Pseudonymisation des données sensibles : Pour limiter l'identification des individus en cas de fuite de données. Chiffrement des données : À la fois en transit et au repos, utilisant des standards AES-256. Authentification à deux facteurs : Pour l'accès aux systèmes internes. Contrôle d'accès basé sur les rôles (RBAC) : Les employés n'ont accès qu'aux données nécessaires à leurs fonctions.		
Violations de données	X-corp a subi une fuite de données mineure il y a un an, exposant 2 000 enregistrements clients. La gestion de cet incident a révélé des lacunes dans le processus de réponse.		

Job 3 : Réalisation d'une DPIA

Introduction

Pour cette analyse d'impact, nous avons choisi d'étudier le traitement des données réalisé par X Corp pour HealthMed.

HealthMed fait appel aux services de X Corp pour suivre 500 000 patients. Les données utilisées comprennent les noms, les adresses, les courriels, les numéros de téléphone, les historiques médicaux et les prescriptions.

Nous avons choisi ce traitement car il utilise des données de santé. Ces données sont beaucoup trop sensibles. Elles pourraient avoir de graves conséquences pour les patients en cas de vol, de perte ou de mauvaise utilisation.

1. Présentation du traitement

Élément	Description
Client de X-Corp	HealthMed
Personnes concernées	500 000 patients

Données collectées	Nom, adresse, courriel, téléphone, historique médical et prescriptions
Objectifs	Suivi des traitements, rappels de rendez-vous et conseils de santé personnalisés
Base légale	Consentement explicite des patients

Durée de conservation	Dix ans après la fin du traitement médical
Stockage	Réalisé avec le partenaire CloudSecure

Dans ce traitement, HealthMed décide comment utiliser les données des patients. X Corp fournit la solution technique pour les organiser, les stocker et les utiliser.

2. Pourquoi faut-il faire une AIPD ?

Une analyse d'impact est nécessaire si un traitement peut poser un risque important pour les personnes.

Le traitement de HealthMed présente un risque élevé pour trois raisons :

il concerne un grand nombre de personnes ;
il utilise des données médicales ;
Une fuite ou une erreur peut avoir de graves conséquences pour les patients.

Par exemple, révéler une maladie ou une ordonnance pourrait violer la vie privée d'un patient.

3. Nécessité du traitement

Les informations d'identité et de contact servent à reconnaître les patients et à leur envoyer des rappels de rendez-vous.

Les informations médicales et les prescriptions sont nécessaires pour suivre les traitements. Cependant, HealthMed et X Corp doivent seulement recueillir les informations vraiment utiles.

La durée de conservation de dix ans doit aussi être vérifiée souvent. Quand les données ne servent plus, il faut les supprimer.

Les informations médicales ne doivent pas servir à faire de la publicité ou des campagnes commerciales.

4. Analyse des risques

Risque Conséquence possible Niveau

Accès non autorisé Une personne peut consulter le dossier médical d’un patient Élevé
Fuite ou vol de données Les informations médicales peuvent être diffusées ou utilisées pour du chantage Élevé
Modification des données Une prescription ou une information médicale peut devenir incorrecte Élevé
Perte des données HealthMed peut ne plus pouvoir accéder au dossier du patient Moyen

Le plus grand risque reste la fuite d'informations médicales. Une personne mal intentionnée pourrait s'en servir pour faire du phishing, du chantage ou nuire à la réputation du patient.

5. Mesures de sécurité déjà en place

X-Corp a déjà mis en place plusieurs protections :

- la pseudonymisation des données sensibles ;
- le chiffrement des données ;
- l’authentification à deux facteurs ;
- le contrôle d’accès selon le rôle des employés ;
- la présence d’un DPO ;
- une politique de conservation des données.

Ces mesures aident à réduire les risques. Cependant, elles ne peuvent pas les éliminer complètement.

6. Améliorations proposées

Nous proposons les améliorations suivantes :

vérifier régulièrement les droits d’accès des employés ;
surveiller les téléchargements importants ou inhabituels ;
conserver un historique des accès et des modifications ;
effectuer régulièrement des sauvegardes ;
tester la restauration des sauvegardes ;
sensibiliser les employés au phishing ;
supprimer les données lorsque la durée de conservation est terminée ;

Conclusion

Notre étude montre que le traitement fait pour HealthMed présente un risque élevé. Il concerne 500 000 patients et contient des données médicales.

X Corp a déjà mis en place plusieurs mesures de sécurité importantes, comme le chiffrement, la pseudonymisation et la double authentification. Cependant, l'entreprise doit mieux surveiller les accès, faire plus de sauvegardes et améliorer la gestion des incidents.

Nous pensons donc que le traitement peut continuer si les mesures de sécurité sont vérifiées régulièrement et améliorées. Il faudra aussi mettre à jour l'analyse d'impact après une violation de données ou un changement important du traitement.

Jour 4 — Simulation d'une violation de données chez X-Corp

Introduction

X-Corp a connu, il y a un an, une fuite de données qui a exposé 2 000 enregistrements clients. La gestion de cet incident a révélé plusieurs problèmes dans la procédure de réponse.

Cette simulation montre les actions à entreprendre en cas d'une violation similaire.

1. Description de l'incident

Un fichier appartenant au client RetailCo a été rendu accessible par erreur. Ce fichier contient les données personnelles de 2 000 clients :

noms et prénoms ;

adresses électroniques ;

numéros de téléphone ;

historiques d'achats ;

préférences de produits.

Aucun mot de passe ni aucune information bancaire n'est concerné.

Cet incident constitue une violation de données personnelles, car des personnes non autorisées ont pu accéder aux informations. Il s'agit plus précisément d'une atteinte à la confidentialité.

2. Conséquences possibles

Cette fuite peut avoir plusieurs conséquences pour les personnes concernées :

réception de courriels frauduleux ;

appels téléphoniques indésirables ;

tentatives de phishing ;

utilisation abusive des habitudes d'achat ;

atteinte à la vie privée.

Même si les données exposées ne sont pas des données médicales ou bancaires, elles permettent d'identifier et de contacter les clients. La violation présente donc un risque pour les personnes.

3. Réaction immédiate

Dès la découverte de la fuite, les actions suivantes doivent être réalisées :

bloquer l'accès au fichier ;

déterminer l'origine de la fuite ;

vérifier si le fichier a été consulté ou téléchargé ;

conserver les journaux de connexion ;

informer le responsable informatique ;

prévenir le DPO ;

informer RetailCo ;

inscrire l'incident dans le registre des violations.

X-Corp ne doit pas attendre la fin de l'enquête pour informer RetailCo.

4. Déroulement de la gestion de l'incident

Moment Action

Découverte Un employé détecte que le fichier est accessible

Première heure L'accès au fichier est bloqué

Dans les heures suivantes Les journaux de connexion sont analysés

Le même jour Le DPO, la direction et RetailCo sont informés

Dans les 24 heures Le nombre de personnes et les données concernées sont vérifiés

Avant 72 heures La CNIL est informée si la violation présente un risque

Après l'incident Des mesures correctives sont mises en place

Le délai de 72 heures commence lorsque le responsable du traitement a connaissance de la violation.

5. Répartition des responsabilités

RetailCo est le responsable du traitement, car l'entreprise décide pourquoi et comment les données de ses clients sont utilisées.

X-Corp est le sous-traitant, car elle traite les données pour le compte de RetailCo.

X-Corp doit donc informer RetailCo de la violation dans les meilleurs délais. RetailCo est ensuite responsable de la notification à la CNIL. X-Corp doit lui fournir toutes les informations nécessaires.

6. Notification à la CNIL

La notification doit notamment contenir :

la nature de la violation ;

le nombre approximatif de personnes concernées ;

les catégories de données exposées ;

les conséquences possibles ;

les mesures prises pour arrêter la fuite ;

les coordonnées du DPO.

Exemple de notification

X-Corp a détecté un accès non autorisé à un fichier contenant environ 2 000 enregistrements appartenant à RetailCo.

Les données concernées sont les noms, les adresses électroniques, les numéros de téléphone, les historiques d'achats et les préférences de produits. Aucun mot de passe ni aucune donnée bancaire ne sont concernés.

L'accès au fichier a été immédiatement bloqué. Une analyse des journaux de connexion est en cours afin de déterminer si les données ont été téléchargées. Les personnes concernées risquent principalement de recevoir des messages frauduleux ou des tentatives de phishing.

7. Information des personnes concernées

Si l'analyse montre que la violation présente un risque élevé, RetailCo doit informer les clients concernés dans les meilleurs délais.

Exemple de message

Objet : Information concernant la sécurité de vos données

Un incident de sécurité a rendu accessibles certaines de vos données personnelles, notamment votre nom, votre adresse électronique, votre numéro de téléphone et votre historique d'achats.

L'accès a été bloqué et une enquête est en cours. Aucun mot de passe ni moyen de paiement n'est concerné.

Il est recommandé de rester vigilant face aux courriels et appels suspects. Aucun mot de passe ou renseignement bancaire ne doit être communiqué à une personne effectuant une demande inattendue.

8. Mesures correctives

À la suite de l'incident, X-Corp doit mettre en place les mesures suivantes :

mieux contrôler les droits d'accès ;

vérifier les fichiers avant leur partage ;

limiter la durée de validité des liens de partage ;

surveiller les téléchargements inhabituels ;

former les employés aux risques de sécurité ;

améliorer la procédure de gestion des incidents ;

effectuer régulièrement des simulations ;

prévoir une procédure rapide pour informer les clients.

Conclusion

Cette simulation montre que la gestion d'une violation de données doit être rapide et organisée.

La première action consiste à bloquer l'accès aux données. Il faut ensuite identifier les informations concernées, conserver les preuves, prévenir le DPO et informer RetailCo.

Lorsque la violation présente un risque pour les personnes, RetailCo doit la notifier à la CNIL dans un délai maximal de 72 heures. Les clients doivent également être informés si le risque est considéré comme élevé.

Job 5 : Audit de conformité RGPD de X-Corp

L'audit de conformité RGPD de X-Corp a pour objectif d'évaluer les pratiques de l'entreprise en matière de protection des données personnelles et d'identifier les éventuels écarts par rapport aux exigences du Règlement général sur la protection des données. L'analyse porte principalement sur les trois activités présentées dans le registre des traitements : la gestion des clients de RetailCo, le suivi des patients de HealthMed et l'analyse de l'utilisation de la plateforme EduLearn. Une attention particulière est accordée au traitement HealthMed, puisqu'il concerne environ 500 000 patients et implique des données de santé particulièrement sensibles. Dans l'ensemble, X-Corp présente un niveau de conformité partiel : plusieurs mesures de protection sont déjà en place, mais certains domaines doivent encore être renforcés.

Registre des traitements

X-Corp dispose d'un registre permettant d'identifier les principaux traitements réalisés pour RetailCo, HealthMed et EduLearn. Pour chaque traitement, les finalités, les personnes concernées, les catégories de données collectées, les bases légales et les durées de conservation sont indiquées. Cette démarche constitue une première base satisfaisante pour assurer la traçabilité des traitements. Toutefois, le registre reste incomplet. Il devrait notamment préciser davantage les destinataires des données, les différents sous-traitants impliqués, les éventuels transferts de données en dehors de l'Espace économique européen ainsi que les mesures générales de sécurité. Pour le traitement HealthMed, il serait par exemple nécessaire d'indiquer clairement que HealthMed agit comme responsable du traitement, X-Corp comme sous-traitant et CloudSecure comme sous-traitant ultérieur. Le

registre doit également être régulièrement actualisé afin de rester conforme aux pratiques réelles de l'entreprise.

Bases légales et consentement

Un autre point d'attention concerne les bases légales. Le registre indique que X-Corp ou ses clients utilisent principalement le consentement pour les traitements RetailCo, HealthMed et EduLearn. Or, le consentement ne constitue pas automatiquement la base juridique appropriée pour tous les traitements. Il est donc nécessaire d'analyser séparément chaque finalité afin de déterminer la base légale la plus adaptée. Le cas de HealthMed est particulièrement sensible puisque le traitement porte sur des données de santé. Il faut alors distinguer la base juridique applicable au traitement au titre de l'article 6 du RGPD et la condition permettant de traiter des catégories particulières de données au titre de l'article 9. Le consentement explicite peut constituer l'une des possibilités prévues par l'article 9, mais son utilisation doit être justifiée et sa preuve conservée. X-Corp et HealthMed devraient donc documenter précisément les bases juridiques retenues.

Minimisation et conservation des données

X-Corp a défini des durées de conservation pour ses principaux traitements. Les données RetailCo sont conservées cinq ans après le dernier contact, celles de HealthMed dix ans après la fin du traitement médical et celles d'EduLearn deux ans après la fin de l'utilisation de la plateforme. La définition de ces durées constitue une mesure positive, mais il est nécessaire de pouvoir justifier chaque durée en fonction de la finalité du traitement et des éventuelles obligations légales applicables. L'entreprise devrait également mettre en place des mécanismes permettant de supprimer ou d'archiver effectivement les informations arrivées à expiration. Concernant HealthMed, l'AIPD met par ailleurs en évidence un risque de collecte excessive de certaines informations médicales. Le principe de minimisation impose de limiter les données aux informations strictement nécessaires au suivi des patients.

Sécurité des données

X-Corp dispose de plusieurs mesures techniques satisfaisantes. Les données sensibles sont pseudonymisées, les données au repos sont chiffrées en AES-256, une authentification à deux facteurs est utilisée et les droits d'accès sont organisés selon les fonctions des collaborateurs grâce à un contrôle d'accès basé sur les rôles. Ces mesures constituent un socle de sécurité important. Néanmoins, la simulation de violation révèle certaines faiblesses. Un compte de support disposant de droits trop importants pourrait notamment permettre l'export d'un volume important de données médicales en cas de compromission. Il serait donc nécessaire de renforcer la sécurité des comptes privilégiés, notamment grâce à une authentification résistante au phishing, de réduire les droits permanents des équipes de support et de mettre en place des accès temporaires. Les exports massifs de données devraient également faire l'objet d'une authentification supplémentaire, d'une validation et d'une surveillance automatique.

Sous-traitance

Le traitement HealthMed implique plusieurs acteurs : HealthMed est responsable du traitement, X-Corp intervient comme sous-traitant et CloudSecure fournit l'infrastructure utilisée par X-Corp. Cette chaîne de sous-traitance nécessite une surveillance particulière.

X-Corp doit s'assurer que CloudSecure présente des garanties suffisantes en matière de protection et de sécurité des données et que les obligations nécessaires sont correctement encadrées contractuellement. Il faut également vérifier la localisation des données et identifier les éventuels transferts vers des pays situés hors de l'Espace économique européen. Par ailleurs, X-Corp ne doit pas réutiliser les données médicales pour des finalités incompatibles avec les instructions de HealthMed. L'utilisation de ces informations à des fins publicitaires ou pour l'amélioration générale d'autres produits nécessiterait notamment une analyse juridique distincte.

Droits des personnes

La gestion des droits des personnes constitue également un domaine à renforcer. Les patients, clients et utilisateurs doivent pouvoir exercer les droits prévus par le RGPD, notamment les droits d'accès, de rectification, d'effacement, d'opposition ou de limitation lorsque ceux-ci sont applicables. L'AIPD indique que X-Corp peut être amenée à traiter de nombreuses demandes. Il serait donc pertinent de mettre en place une procédure centralisée permettant d'enregistrer chaque demande, de vérifier son traitement dans les délais applicables et de conserver une preuve de la réponse apportée. Un portail dédié ou un outil de suivi pourrait faciliter cette gestion et réduire le risque qu'une demande ne soit pas correctement traitée.

Analyse d'impact relative à la protection des données

L'AIPD réalisée pour HealthMed constitue l'un des points les plus solides de la démarche de conformité. Sa réalisation est particulièrement importante puisque le traitement concerne à grande échelle des données de santé d'environ 500 000 patients. L'analyse identifie les principaux risques, notamment l'exfiltration de données médicales, les accès internes abusifs, la réidentification des données pseudonymisées, les erreurs concernant les prescriptions et la conservation excessive des informations. Des mesures supplémentaires ont également été définies afin de réduire ces risques. Avant le déploiement complet du traitement, les actions considérées comme prioritaires devraient toutefois être réalisées et les risques résiduels formellement examinés et acceptés par le responsable du traitement.

Gestion des violations de données

La gestion des violations représente un autre point important de l'audit. X-Corp a déjà subi une fuite ayant exposé environ 2 000 enregistrements clients, et cet incident avait mis en évidence certaines lacunes dans son processus de réponse. La simulation réalisée pour HealthMed montre néanmoins une amélioration importante. Elle prévoit la détection de l'incident, la désactivation du compte compromis, la révocation des sessions, la conservation des preuves techniques, l'activation d'une cellule de crise et l'information rapide de HealthMed. Dans ce contexte, X-Corp doit, en tant que sous-traitant, informer HealthMed de la violation dans les meilleurs délais. HealthMed, en qualité de responsable du traitement, doit ensuite évaluer les risques et déterminer les obligations de notification à la CNIL et de communication aux patients concernés. Des exercices réguliers permettraient de vérifier que cette procédure fonctionne réellement en situation de crise.

Conclusion

L'audit permet de conclure que X-Corp présente un niveau de **conformité RGPD partiel**. L'entreprise dispose déjà de plusieurs éléments positifs, notamment un DPO, un registre des

traitements, des mesures de chiffrement et de pseudonymisation, un contrôle des accès ainsi qu'une AIPD détaillée pour le traitement HealthMed. Ces dispositifs montrent que la protection des données est déjà intégrée dans l'organisation.

Cependant, plusieurs améliorations restent nécessaires. Les priorités concernent principalement la vérification des bases légales, l'enrichissement du registre des traitements, la sécurisation des comptes privilégiés, le contrôle des exports massifs de données, la justification des durées de conservation, la surveillance de CloudSecure et l'amélioration du traitement des demandes d'exercice des droits. La procédure de gestion des violations doit également continuer à être testée régulièrement.

En conclusion, X-Corp dispose d'une base sérieuse pour atteindre un niveau satisfaisant de conformité, mais certains risques demeurent importants, particulièrement pour HealthMed en raison du volume et de la sensibilité des données médicales traitées. Les actions de sécurité et de conformité considérées comme prioritaires devraient donc être mises en œuvre avant le déploiement complet du traitement. Un suivi régulier permettra ensuite de vérifier leur efficacité et d'adapter la conformité de X-Corp à l'évolution de ses activités.